

Offensive Security Operating Model for the AI Transformation

One-page summary — the shift, the model, the infrastructure, the ask.

The shift

- From gatekeeper to embedded advisor and continuous validator — the empirical truth function for AI risk.
- Pre-deployment review cannot scale to hundreds of citizen-developer apps; the response is to redesign the model, not review harder.

Three operating principles

- Paved road over gates** — sanctioned gateway, vetted MCP registry, secure-by-default templates. Adoption is the enforcement mechanism.
- Risk-tiered engagement** — human depth on Tier 1-2; Tier 3-4 ride automated assurance with sampled red team validation.
- Continuous validation** — replace point-in-time pre-deploy review with post-deploy validation, hunting, and control testing.

Risk tiering — how effort scales

- Tier 1** — PHI / clinical / external-facing. Embedded AppSec partner, manual red team, continuous control validation.
- Tier 2** — Sensitive internal action / write-back to systems of record. Embedded review, manual red team for material changes.
- Tier 3** — Internal advisory with broad reach. Async checklist review, automated red team, continuous monitoring.
- Tier 4** — Low-impact assistive. Paved-road template, automated scanning, baseline logging, no human review unless flags fire.

Dimensions: data sensitivity · decision impact · integration footprint · user population. Re-tier on material change, incident, regulatory shift, or annual recert.

Sanctioned AI infrastructure — six layers

- AI gateway** — only sanctioned path to Claude and approved models; identity, data-class routing, prompt DLP/PHI redaction, output filtering, quotas, full logging.
- MCP server farm** — curated registry, no BYO; tier inherited from MCP to calling agent; scoped short-lived tokens; tool-call logging.
- Agent runtime** — managed workloads with workload identity, scoped tool allow-list, validated eval suite, sandbox, kill-switch, recert.
- AI-aware SDLC** — five stages with automated checks at every tier and gates calibrated to tier (intake → design → build → pre-prod → production).
- Network provisioning** — per-tier subnets, mTLS east-west, TLS-inspecting egress, default-deny allow-list, end-user shadow-AI block.
- Unified AI telemetry** — prompts, completions, tool calls, retrievals, agent decisions, policy events with identity context — to SIEM, hunt, control validation, owner dashboards.

Phased capability roadmap (18 months)

Phase 1 — Demonstrate	Phase 2 — Build the paved road	Phase 3 — Measure	Phase 4 — Institutionalize
Existing headcount; reprioritize toward AI. Demonstration red team reframes every later budget conversation.	Gateway, MCP farm, agent runtime, AI-aware SDLC. Selective specialist hiring. Paved-road UX as first-class concern.	Continuous control validation for AI; board / risk-committee metrics; sharpened ask informed by data.	Quarterly state-of-AI-security cadence; durable RACI; the seat at the table outlives organizational change.

What we are asking from the CISO and cyber executive team

- Operating model approval — gatekeeper → embedded advisor + continuous validator; risk-tiered engagement as the standard.
- Risk-tiering adoption — four tiers, socialized with AI governance, privacy, compliance.
- AI infrastructure endorsement — gateway, MCP farm, agent runtime, AI-aware SDLC, network provisioning.
- RACI ratification — offensive security owns the discipline; platform engineering operates the controls.
- Phase 1 authorization — within existing headcount and operating budget; training and tooling PoC funding.
- Executive air cover — sponsorship in AI transformation forums, AI governance, and BU leader conversations.
- Reporting cadence — quarterly state-of-AI-security report to cyber exec team and risk committee.